BP DIGITAL BANKING

Propuesta de arquitectura de soluciones | Ejercicio técnico DEVSU

Documento autocontenido para evaluación: modelos C4, flujos, infraestructura, decisiones arquitectónicas, patrones y metodologías, seguridad, continuidad, costos y trazabilidad.

Versión	Naturaleza del documento	Base de evaluación	Fecha
2.0	Propuesta de diseño; no implementación	Ejercicio práctico de BP	01-11-2026

El diseño presenta una solución de referencia. Las metas de disponibilidad, latencia, recuperación y capacidad son supuestos sujetos a confirmación; no se presentan como resultados medidos.

Índice y guía de lectura

Páginas	Contenido
3–5	Resumen ejecutivo, alcance, requisitos y arquitectura de canales
6–7	Metodología de diseño y patrones arquitectónicos aplicados
8–10	C4: contexto, contenedores y componentes
11–14	Secuencias de negocio e infraestructura AWS
15–16	ADR-001 a ADR-006: tablas comparativas, decisiones y dos fundamentos
17–19	Seguridad, calidad, continuidad, capacidad y costos
20–22	Trazabilidad, riesgos, validación y conclusiones

Convenciones: E = requisito explícito del ejercicio; P = propuesta arquitectónica; S = supuesto por validar. Las vistas describen el diseño objetivo, no una implementación ejecutada.

1. Resumen ejecutivo

BP requiere banca digital web y móvil para consultas, transferencias propias e interbancarias, pagos y onboarding facial. Los datos básicos, productos y movimientos proceden del Core; el detalle del cliente, de un sistema complementario. La propuesta reutiliza el producto OAuth 2.0 existente, establece servicios cohesionados y desacopla auditoría y notificaciones mediante eventos.

Se propone AWS como plataforma de referencia con API Gateway, ECS Fargate Multi-AZ, Aurora PostgreSQL, Redis y EventBridge/SQS. La elección no es una restricción del reto; Azure sería viable si las condiciones organizacionales favorecen ese ecosistema.

Principios de arquitectura

Principio	Aplicación
Core como sistema de registro	No replicar saldos definitivos en caché ni tratar la BD de canales como libro mayor.
Integridad antes que disponibilidad aparente	Ante timeout ambiguo, conciliar; no reintentar ciegamente una orden financiera.
Defensa en profundidad	OIDC/PKCE, autorización por cuenta, secretos gestionados y auditoría.
Desacoplamiento	Puertos/adaptadores hacia legados; Transactional Outbox y consumidores idempotentes.
Operabilidad	SLO propuestos, telemetría, DLQ, runbooks, auto-healing y DR probado.

2. Alcance, requisitos y restricciones

IDs	Requisitos explícitos del reto
RF-01 a RF-04	Histórico de movimientos; transferencias propias e interbancarias; pagos.
RF-05 y RF-06	Core + fuente complementaria de cliente; al menos dos sistemas de notificación.
RF-07 a RF-11	SPA, móvil multiplataforma, OAuth2 existente, onboarding facial y acceso posterior.
RF-12 a RF-14	Auditoría de todas las acciones, persistencia para clientes frecuentes y Gateway con tres servicios iniciales.
RNF-01 a RNF-09	HA, tolerancia a fallos, DR, seguridad, monitoreo, auto-healing, latencia, desacoplamiento, normativa y costos.

Extensiones propuestas: RF-15 servicios complementarios de pagos/notificaciones; RF-16 consulta de estado y conciliación. Supuestos: RNF-10 disponibilidad 99,95%; RNF-11 p95 interno ≤ 500 ms; RNF-12 RTO ≤ 60 min y RPO ≤ 15 min. Son objetivos de discusión, no SLA de BP.

Fuera del alcance: implementar Core, desarrollar IdP desde cero, acreditar cumplimiento normativo o demostrar resultados de carga/DR sin pruebas.

3. Canales y modelo de seguridad de acceso

Capa	Propuesta	Alternativa y criterio
SPA	React + TypeScript; BFF y sesión web segura	Angular: estructura más prescriptiva; React favorece composición y tipado de contratos.
Móvil	Flutter iOS/Android, navegador de sistema, PKCE	React Native: reutiliza JavaScript; verificar compatibilidad con SDK facial nativo.
Identidad	IdP existente con OIDC, Authorization Code + PKCE S256	Password + MFA como fallback; passkeys/WebAuthn si el IdP soporta.
Onboarding	Verificación documental y liveness con proveedor especializado	Revisión manual ante resultados ambiguos.

La verificación facial del alta no equivale a biometría local de acceso. En web se prefiere BFF con cookies HttpOnly/Secure/SameSite, CSRF y CSP; en móvil, tokens en almacenamiento seguro y navegador del sistema.

4. Metodología para elaborar la solución

El análisis parte de los requisitos del negocio y los atributos de calidad; evoluciona desde el contexto hasta los componentes, y verifica cada decisión contra seguridad, integración, continuidad y costo.

Enfoque / metodología	Aplicación en BP	Resultado esperado
C4 Model	Descomposición en contexto, contenedores y componentes; relaciones con Core y terceros.	Comunicación progresiva para audiencias de negocio y técnicas.
DDD estratégico	Límites por capacidades: perfil, movimientos, transferencias/pagos, onboarding, auditoría y notificaciones.	Alta cohesión, ownership de datos y responsabilidades explícitas.
Arquitectura hexagonal / Ports & Adapters	Casos de uso independientes de APIs del Core, proveedores biométricos y servicios cloud.	Sustitución de integraciones con menor impacto de negocio.
Architecture Decision Records (ADR)	Decisiones con contexto, alternativas, fundamentos, consecuencias y criterios de validación.	Trazabilidad de trade-offs y decisiones revisables.
Escenarios de atributos de calidad	Definir estímulo, respuesta y medida para HA, latencia, seguridad, DR y auditoría.	Requisitos no funcionales verificables; supuestos visibles.
Threat modeling y defensa en profundidad	Revisar límites de confianza, amenazas de identidad, acceso a cuentas y fraude.	Controles preventivos, detectivos y de recuperación.

Principios transversales: SOLID en componentes, separación de responsabilidades, KISS para evitar complejidad prematura, YAGNI para capacidades no justificadas y diseño seguro por defecto.

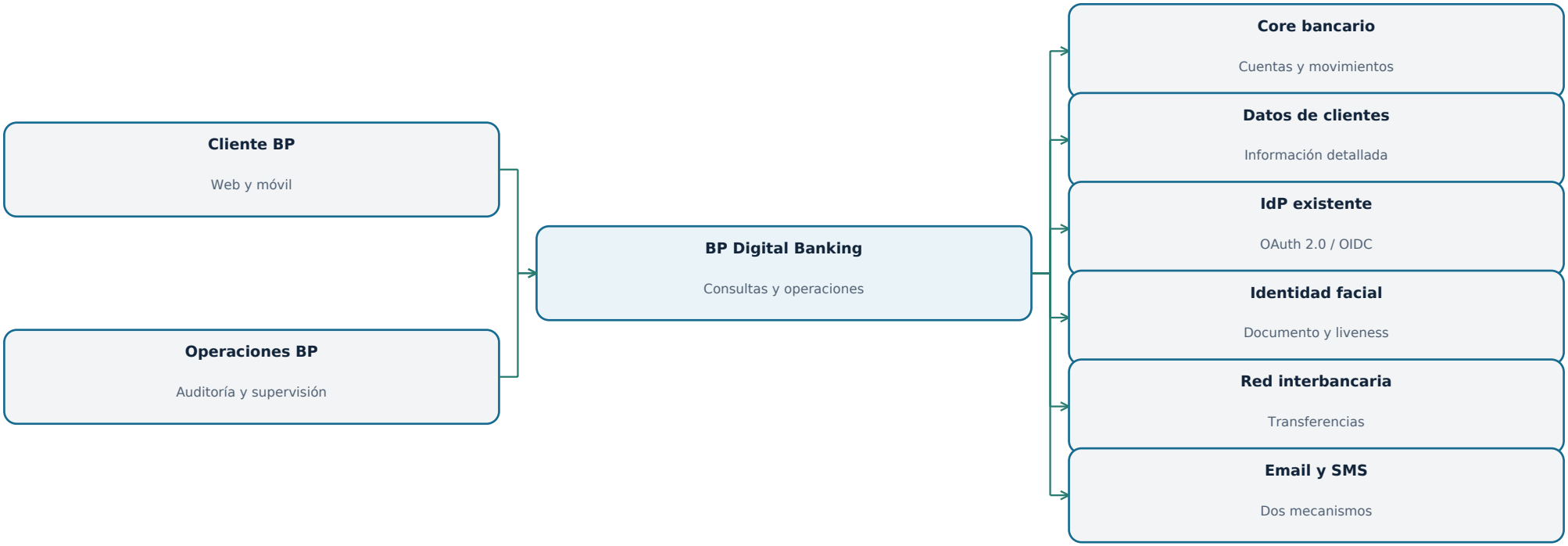
5. Patrones de diseño y arquitectura aplicados

Patrón	Dónde se aplica	Justificación y trade-off
API Gateway + BFF	Acceso SPA/móvil y composición de servicios.	Centraliza controles de borde; el BFF reduce exposición de tokens web. Evitar concentrar lógica de dominio.
Cache-Aside	Lecturas frecuentes de perfil con Redis.	Reduce presión sobre Core; exige TTL, invalidación y aislamiento por cliente.
Transactional Outbox	Estado financiero y evidencia local en Aurora; publicador hacia eventos.	Evita dual-write no atómico; requiere worker y consumidores idempotentes.
Idempotent Consumer / Idempotency Key	Órdenes financieras, auditoría y notificaciones.	Mitiga duplicados por reintentos y entrega al menos una vez; requiere claves y deduplicación.
Anti-Corruption Layer (ACL)	Adaptadores Core, red interbancaria y proveedor facial.	Protege el dominio frente a contratos externos; añade traducción y mantenimiento.
Circuit Breaker + Timeout + Bulkhead	Llamadas a Core, IdP y terceros.	Limita fallos en cascada; requiere umbrales y métricas calibradas.
Retry + Backoff + DLQ	Notificaciones y procesamiento asíncrono.	Recupera fallos transitorios; no aplicar reintento ciego a órdenes financieras.
CQRS ligero	Separación de consultas de perfil/movimientos y comandos financieros.	Simplifica políticas de lectura y escritura; no implica event sourcing.
Observability / Correlation ID	BFF, servicios, adaptadores, eventos y auditoría.	Permite trazabilidad extremo a extremo sin registrar información sensible.

Las elecciones son propuestas justificadas; su aceptación depende de contratos reales, pruebas de resiliencia y restricciones de BP.

4. C4 — Nivel 1: contexto

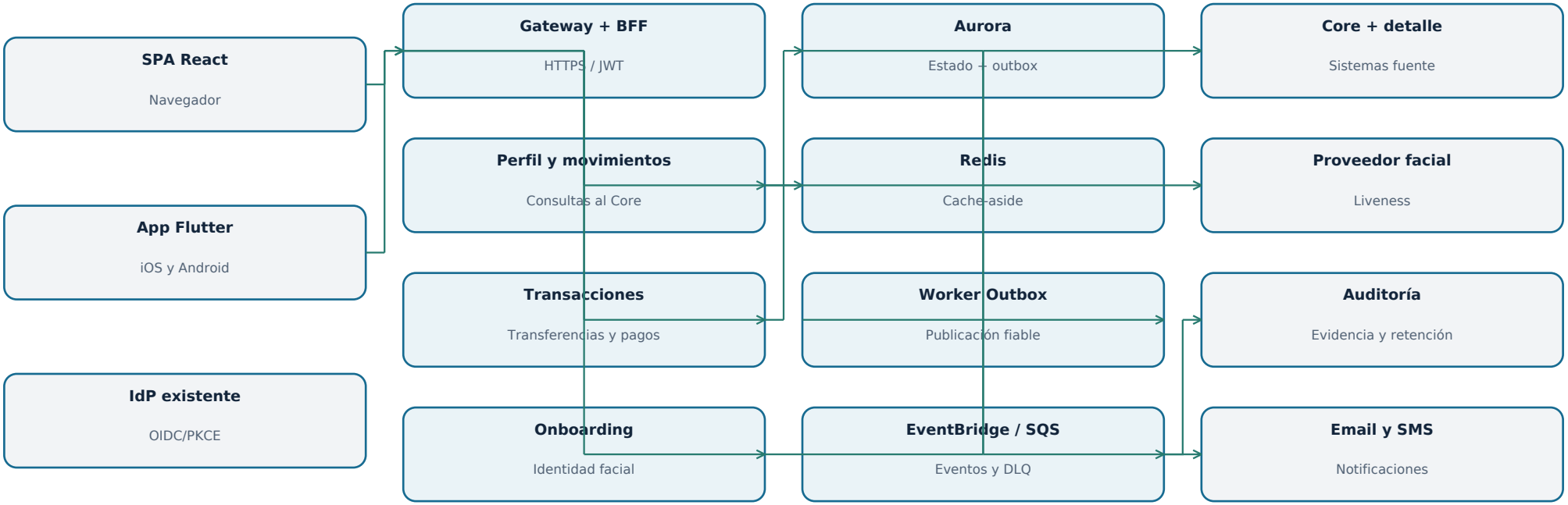
Figura 1. Contexto lógico BP y sistemas externos



La plataforma es la experiencia digital; el Core conserva la fuente de verdad. Operaciones accede a evidencias con autorización restringida. La red interbancaria puede integrarse a través del Core: la topología definitiva se confirmará con BP.

5. C4 — Nivel 2: contenedores

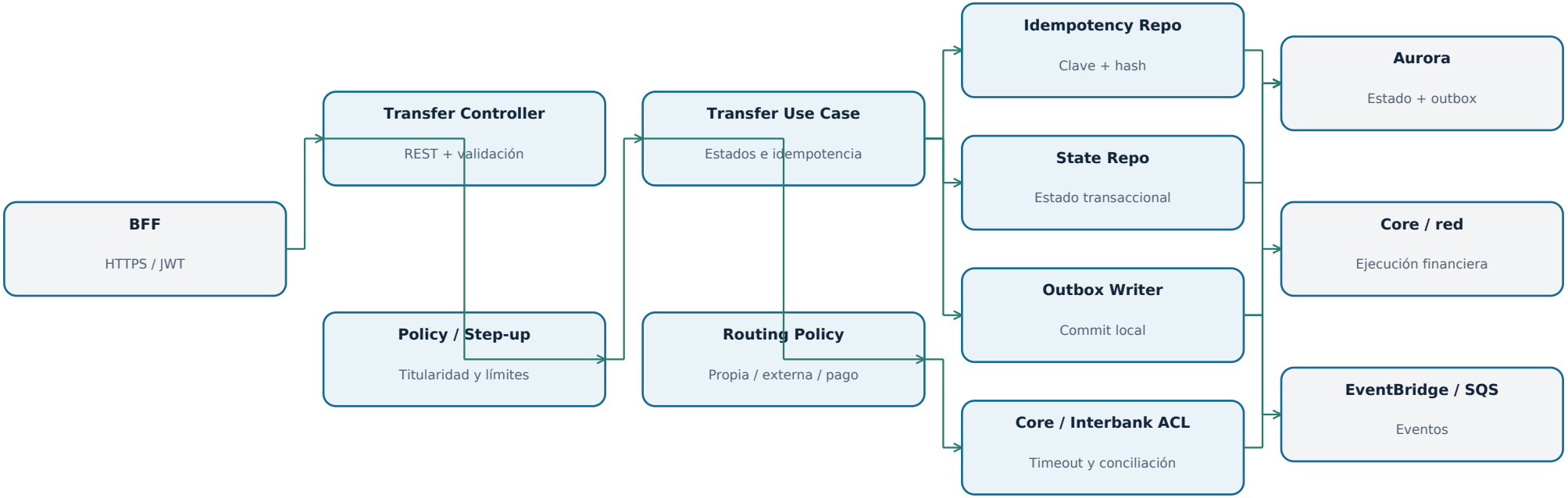
Figura 2. Contenedores y principales dependencias



Vista agrupada para legibilidad: Perfil y Movimientos son servicios separados en el modelo fuente; Notificaciones y Auditoría son consumidores independientes. La conexión outbox es transaccional en Aurora y asíncrona hacia el bus. No se permite acceso a tablas privadas de otro servicio.

6. C4 — Nivel 3: servicio transaccional

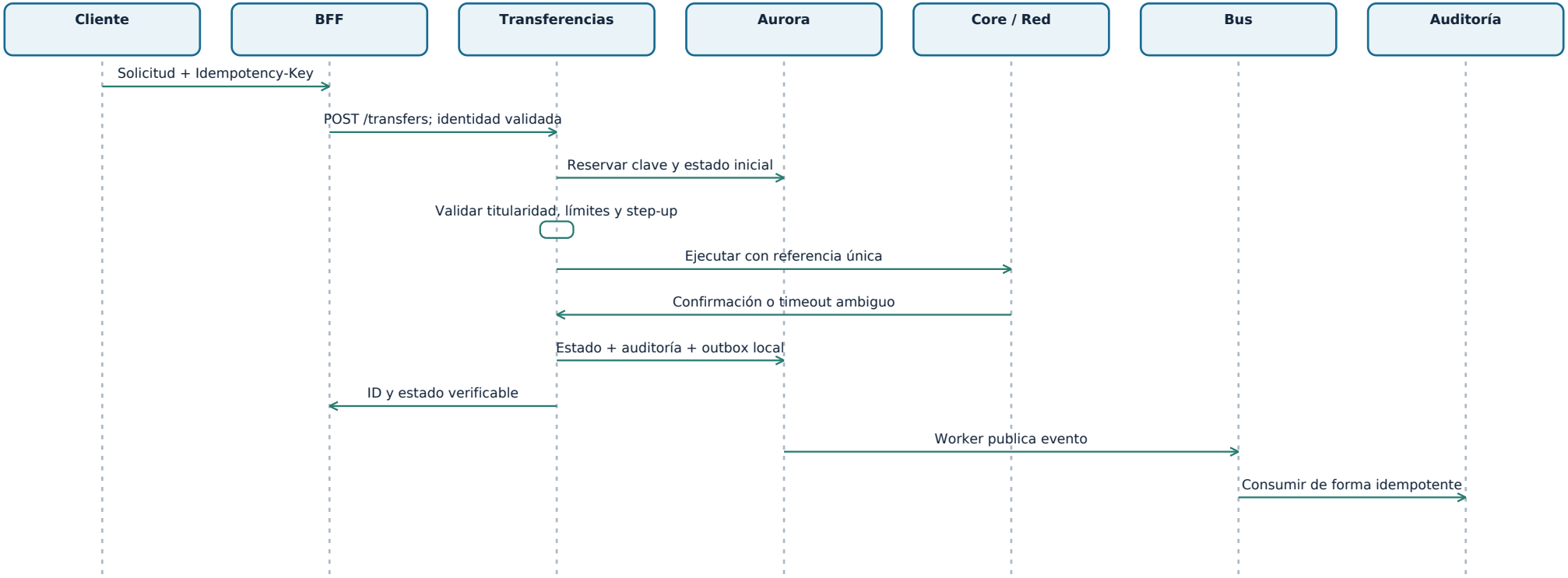
Figura 3. Componentes lógicos y límites de responsabilidad



La flecha Outbox → Bus resume el flujo lógico; la publicación real la ejecuta un worker separado que lee el outbox confirmado. El caso de uso no depende directamente del SDK AWS ni del protocolo legado. La autorización de cuenta se valida en backend.

7. Secuencia — transferencia y conciliación

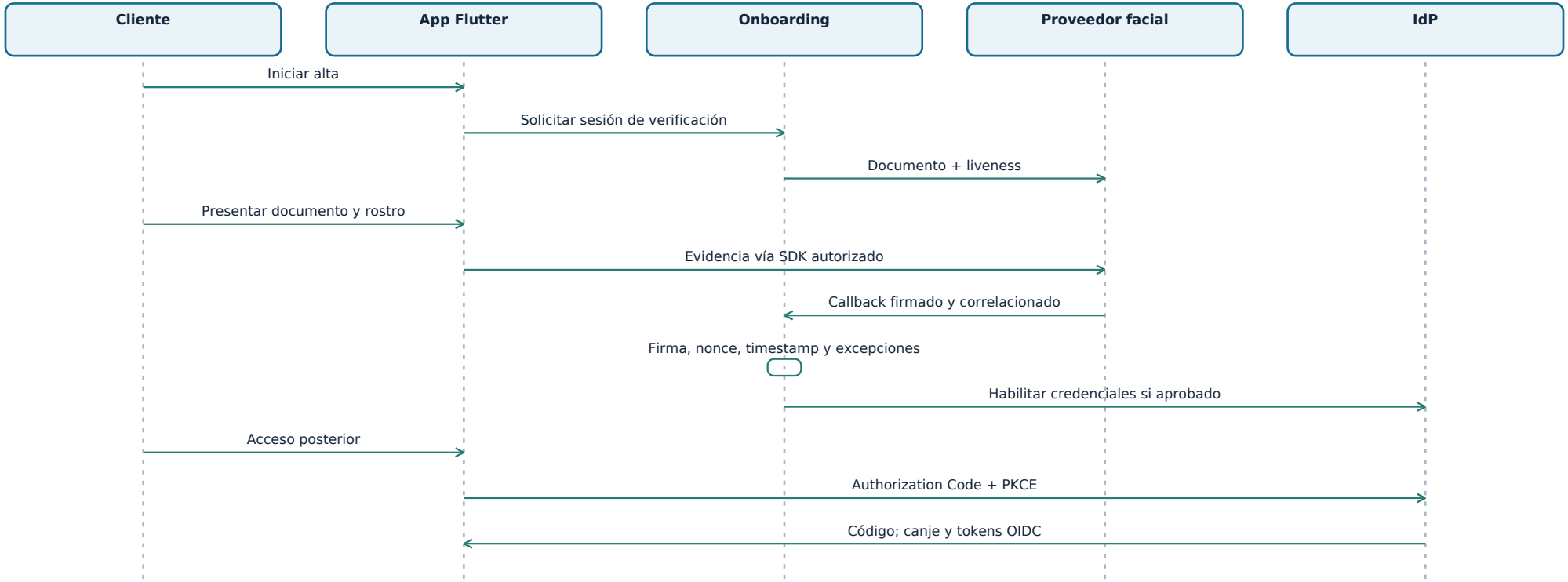
Figura 4. Flujo transaccional y evidencia



Invariante: timeout posterior al envío no implica rechazo ni autoriza segundo débito. Se asigna PENDING_RECONCILIATION y se consulta por referencia hasta resolver; no se asume reverso automático. Los eventos pueden llegar más de una vez.

8. Secuencia — onboarding y autenticación

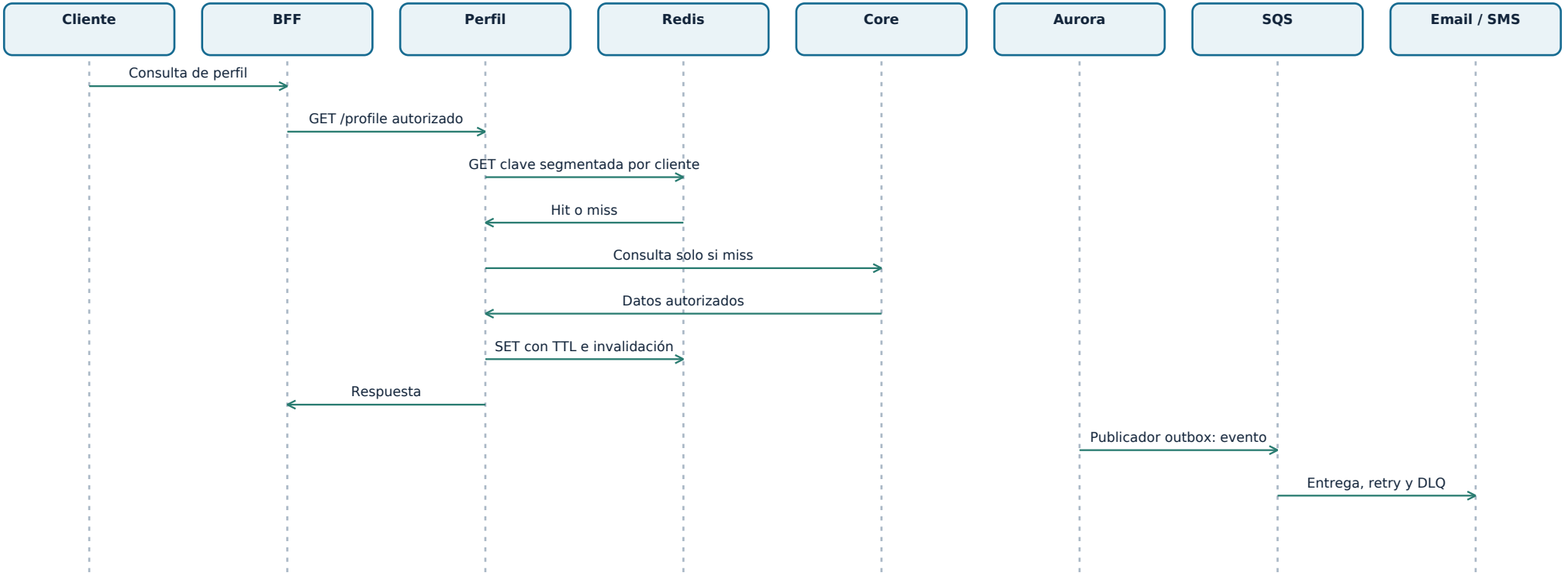
Figura 5. Alta de identidad y acceso posterior



Las rutas de rechazo e incertidumbre llevan a revisión manual o rechazo. Se proponen MFA adaptativa y passkeys si el IdP lo permite. No almacenar plantillas biométricas en servicios BP salvo justificación legal y técnica.

9. Secuencia — caché, auditoría y notificaciones

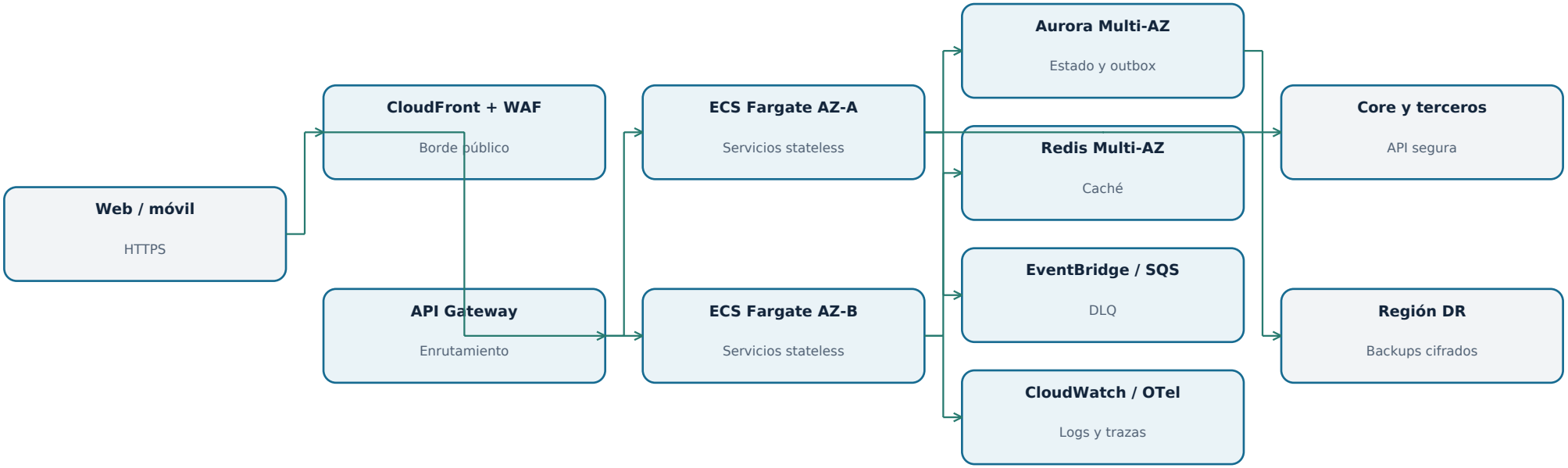
Figura 6. Cache-aside y eventos de operación



El flujo combina dos casos lógicos: lectura frecuente de perfil y distribución posterior de eventos financieros. Auditoría recibe el mismo evento mediante consumidor independiente con deduplicación y política de retención; el envío de correo/SMS no bloquea la confirmación de una operación.

10. Despliegue lógico AWS

Figura 7. Infraestructura lógica y recuperación



Los servicios se alojan en subredes privadas de al menos dos zonas. API Gateway requiere integración privada compatible (VPC Link y balanceador según tipo de API). Los objetivos regionales de DR dependen de restauración ensayada y residencia de datos. Multi-AZ no sustituye DR multi-región.

11. Decisiones arquitectónicas — ADR en tablas

Estado de los seis ADR: propuesto. Cada decisión incluye alternativas y dos fundamentos independientes.

ADR / decisión	Alternativas evaluadas	Dos fundamentos teóricos
ADR-001 — Plataforma AWS CloudFront/WAF, API Gateway, ECS Fargate Multi-AZ, Aurora, Redis, EventBridge/SQS y CloudWatch.	Azure; EKS/Kubernetes.	1) Servicios gestionados reducen mantenimiento y parches. 2) Multi-AZ, escalado y observabilidad favorecen aislamiento y recuperación.
ADR-002 — Canales web y móvil React + TypeScript SPA y Flutter móvil; OIDC/PKCE y BFF web.	Angular; React Native.	1) React y TypeScript facilitan reutilización y contratos tipados. 2) Flutter comparte lógica/UI entre iOS y Android e integra SDK nativo.
ADR-003 — Identidad y onboarding IdP existente con OIDC, Authorization Code + PKCE S256; verificación documental y liveness.	Password + MFA; passkeys; construir IdP nuevo (descartado).	1) PKCE mitiga interceptación de código; OIDC estandariza identidad. 2) Separar prueba de identidad y autenticación reduce exposición biométrica.

Criterio de aceptación: contrastar cada decisión con requisitos, capacidades reales de BP, riesgos de seguridad, pruebas de integración y costo operativo.

12. Decisiones arquitectónicas — ADR en tablas

Estado de los seis ADR: propuesto. Cada decisión incluye alternativas y dos fundamentos independientes.

ADR / decisión	Alternativas evaluadas	Dos fundamentos teóricos
ADR-004 — Datos y eventos Aurora para estado propio; Redis Cache-Aside; Outbox, EventBridge/SQS y auditoría durable.	MSK/Kafka; event sourcing.	1) Cache-Aside evita consultas repetidas al Core sin duplicar autoridad. 2) Outbox evita dual-write no atómico y soporta reintentos.
ADR-005 — Límites de servicio Perfil, movimientos, transacciones, onboarding, notificaciones y auditoría con ACL.	Monolito modular; microservicio por endpoint.	1) Límites de capacidad concentran reglas y ownership. 2) ACL desacopla cambios de Core y sistemas externos.
ADR-006 — Resiliencia y operación Multi-AZ, servicios stateless, circuit breaker, bulkhead, OTel, backups y autorización fina.	Active-active multi-región; service mesh.	1) Aislamiento por zona y proveedor reduce cascadas. 2) Trazas y runbooks reducen diagnóstico; autorización por recurso limita accesos.

Criterio de aceptación: contrastar cada decisión con requisitos, capacidades reales de BP, riesgos de seguridad, pruebas de integración y costo operativo.

13. Seguridad, auditoría y regulación

Riesgo / requisito	Control de diseño	Verificación futura
Acceso a cuentas ajenas	Autorización por titularidad, scopes y atributos; no confiar en accountId del cliente	Pruebas IDOR y acceso cruzado
Robo de sesión/token	OIDC, PKCE, cookies seguras BFF, almacenamiento seguro móvil	Pruebas de sesión y revocación
Fraude en onboarding	Liveness, documento, callback firmado y revisión manual	Callbacks falsos, replay y expiración
PII y biometría	Minimización, KMS, retención, segregación y no almacenar plantillas por defecto	Revisión legal y privacidad
Auditoría de todas las acciones	Quién, qué, cuándo, resultado, canal y correlación; sin tokens/secretos	Conciliación de eventos, integridad y retención
DDoS y secretos	WAF, rate limit, IAM mínimo privilegio y Secrets Manager	Pruebas de seguridad y permisos

La jurisdicción Ecuador es un supuesto del análisis: evaluar LOPDP, normas aplicables de la Superintendencia de Bancos y reglas del sistema de pagos. ISO 27001, OWASP ASVS/MASVS y NIST son referencias; PCI DSS solo si se procesan datos de tarjetas dentro de su alcance. La aplicabilidad requiere revisión jurídica.

14. Calidad, continuidad y monitoreo

Atributo	Objetivo propuesto (no medido)	Mecanismo y prueba
Disponibilidad	99,95 % mensual del canal, condicionado a Core	ECS Multi-AZ, failover Aurora; simulación de pérdida AZ
Latencia	p95 ≤ 500 ms tramo BP sin Core externo	Redis, índices y trazas; carga con caché caliente
Continuidad	RTO ≤ 60 min / RPO ≤ 15 min para datos propios	Backups cross-region si permitidos y simulacro
Integridad	Sin doble débito por reintento	Idempotency-Key persistida, conciliación; inyección de timeout
Mensajería	Entrega al menos una vez; duplicados posibles	Outbox, dedupe, reintentos, DLQ; prueba de caída
Operación	Auto-healing ante fallo de tarea	Health checks ECS, autoscaling y alertas

Telemetría: trazas distribuidas, RED (rate/errors/duration), saturación, edad del outbox, profundidad DLQ, latencia de Core, fallos por proveedor y operaciones pendientes de conciliación. Logs estructurados sin credenciales ni PII. No se declaran pruebas ejecutadas.

15. Capacidad, costos y FinOps

Supuestos de modelado, no cifras proporcionadas por BP: 100.000 registrados, 10.000 activos diarios, pico de 100 solicitudes/s de consulta y 10 operaciones financieras/s; dos AZ; 30 días de logs calientes. Deben contrastarse con telemetría y patrones reales.

Escenario	Volumen relativo	Consideraciones
Bajo	0,5×	Capacidad base multi-AZ, evitar sobredimensionamiento
Base	1×	Escalado Fargate y límites de conexiones al Core
Alto	3×	Cuotas, concurrencia, caché, DLQ y capacidad de terceros

Modelo de costo mensual: Fargate (vCPU-h + GB-h) + API Gateway + CloudFront/WAF + Aurora (cómputo, almacenamiento, IO, backups) + Redis + SQS/EventBridge + red/egress/NAT + CloudWatch/OTel + KMS/Secrets + contingencia. No se incluyen importes monetarios sin región, configuración y cotización.

FinOps: tagging, presupuestos, alertas de anomalías, retención controlada, límites de escalado y revisión periódica de gasto. Comparar ECS/EKS, Aurora/RDS y EventBridge/SQS/MSK con cargas verificadas.

16. Trazabilidad de los criterios de evaluación

Criterio del ejercicio	Evidencia incluida en este PDF
C4 contexto, contenedores y componentes	Figuras 1–3 y explicaciones de límites, seguridad y cloud
Integraciones externas y onboarding	Figuras 1, 4, 5; ADR-003 y ADR-005
Patrones y desacoplamiento	C4 L3, Cache-Aside, ACL, Outbox, idempotencia; ADR-004/005
Front-end web y móvil	Sección 3 y ADR-002 con alternativas
Autenticación y auditoría	Secciones 3, 8, 9, 13; ADR-003/004
Nube, HA, DR y auto-healing	Figura 7, secciones 10 y 14; ADR-001/006
Costos y monitoreo	Secciones 14 y 15
Normativa y seguridad	Sección 13 y controles de diseño
Justificación teórica mínima 2/decisión	Secciones 11–12: dos fundamentos por cada ADR

RF-01 a RF-14 y RNF-01 a RNF-09 son el alcance explícito. RF-15/16 y RNF-13/14 son propuestas; RNF-10/11/12 son supuestos. La matriz de trazabilidad de trabajo contiene el detalle de cada identificador.

17. Riesgos residuales y validación

Riesgo	Mitigación / evidencia requerida
Core y terceros no disponibles	Timeout, circuit breaker, degradación segura y SLA acordados
Operación duplicada o respuesta ambigua	Idempotencia, referencias externas, reconciliación y prueba TI-01/TI-02
Auditoría incompleta de lecturas y denegaciones	Catálogo de eventos de acciones del cliente, pruebas de integridad y cobertura
Red interbancaria con topología desconocida	Contrato real, ownership y validación del adaptador
DR sin evidencia de recuperación	Simulacro con RTO/RPO por dominio y evidencias
Costo y capacidad no contrastados	AWS Pricing Calculator, región, volumen y prueba de carga
Normativa y datos sensibles	Revisión de DPO/Legal, clasificación, residencia y retención

Criterios de aceptación para una implementación futura

TI-01: 20 solicitudes concurrentes con la misma clave producen una sola ejecución lógica. TI-02: timeout tras confirmación externa no genera segundo débito. TI-03: caída tras commit conserva evento outbox. TI-04: duplicado no duplica efecto. TI-05: cuenta ajena retorna rechazo. TI-06: fallo de notificador no revierte transferencia. Todos son casos propuestos; no ejecutados.

18. Conclusión y referencias

La arquitectura de referencia responde al ejercicio BP con tres vistas C4, flujos críticos, infraestructura AWS, seis ADR con dos justificaciones por decisión y patrones explícitos de integración, datos y resiliencia.

El diseño conserva al Core como fuente de verdad bancaria, separa las capacidades de negocio, previene reintentos financieros inseguros y propone auditoría durable y notificaciones desacopladas.

Antes de su adopción se deben confirmar los contratos del Core, límites regulatorios, SLA, volúmenes, retención de datos, pruebas de seguridad y recuperación, y costos regionales. Este documento es una propuesta de arquitectura, no una certificación de implementación.

Referencias conceptuales

Marco / estándar	Aplicación en la propuesta
Modelo C4	Vistas de contexto, contenedores y componentes.
Domain-Driven Design y arquitectura hexagonal	Límites de capacidad, casos de uso y adaptadores.
OAuth 2.0, OpenID Connect y PKCE	Autenticación y autorización de canales.
OWASP ASVS / MASVS, ISO/IEC 27001	Controles de seguridad y verificación de aplicaciones.
LOPDP y regulación bancaria aplicable	Consideraciones sujetas a validación jurisdiccional y legal.
Transactional Outbox, Cache-Aside, Circuit Breaker	Integridad de eventos, eficiencia de lectura y resiliencia.

Fecha de corte: 01 de noviembre de 2026. Los objetivos cuantitativos del documento se identifican como supuestos de diseño.